Security testing evidence

Gavel for Zoom Meetings · prepared 2026-10-20 · contact sankritya.apps@gmail.com

Static analysis (SAST)

Tool	Scope	Result
GitHub CodeQL, `security-extended`	All JavaScript and TypeScript in the repository	Run 39355252934 on 2026-10-20: succeeded, 0 alerts. Run on every push, every pull request and weekly.

Run record: github.com/Sankritya T/zoom-gavel/actions/runs/39355252934

Dependency analysis

Check	Result
`npm audit --omit=dev` (shipped dependencies)	0 vulnerabilities after the 2026-10-19 update of Next.js to 16.4.2. Before it: 1 critical (Next.js), 2 high (sharp, source-map-js). Remaining advisories are in development-only lint tooling and are not shipped.

Dynamic and black-box testing

There is no commercial web scanner. Testing is done by sending real requests to the running application, locally and against the live site, in an automated suite of 191 assertions plus load tests. Areas covered:

- Concurrency: bid storms, identical amounts, expiry boundary, simultaneous Buy Now, colliding clock extensions.
- Authentication and authorization: forged and expired identity cookies, host-only and co-host-only actions refused to attendees, notices signed with a wrong token refused, stale timestamps refused.
- Privacy: another bidder's amount and max bid never returned; guests cannot act as another guest by name.
- OAuth: forged state, missing or tampered handshake cookie, replayed or copied handshake, open-redirect attempts, refused consent.
- Input validation: malformed bodies, out-of-range numbers, bad session keys, oversized webhook bodies, cross-site request rejection.
- Rate limiting: per IP and per bidder.

Load

Test	Result

100 live streams on one auction, live site	Every stream received a bid in about 400 ms.
Up to 300 simulated bidders on a local production build against the live database	No server errors; ledger checks in SQL all clean (prices only rise, each round recorded once, the highest max bid wins).
Bid function inside the database	About 1.4 ms per bid (about 700 per second on one connection).

Independent code reviews (October 2026)

Date	Scope	Outcome
2026-10-09	In-meeting panel: queue, max bid, alerts	10 findings; 8 fixed, the rest accepted and documented.
2026-10-19	Lot queue, max bids, realtime hub, SQL grants	No exploitable issue; 3 hardenings applied (one key rule on every route, no stream for a session nobody created, queue id bounds).
2026-10-19	Sign in with Zoom (OAuth), co-hosts, guest secret, tie rule	No serious finding; 6 low-severity items fixed (pinned redirect origin, single-use handshake, separate signature label, test-only Zoom overrides disabled in production, Zoom-verified name used for browser sign-ins, ordering of co-host notices).

Not done

There has been no third-party penetration test and no commercial DAST scan.

Repository: github.com/SankrityaT/zoom-gavel